M.A.I. CONSULTING · SAMPLE DELIVERABLE

AI Use Policy

Illustrative example of the policy a client receives: permissions first, red lines, data classes, approved tools, disclosure, escalation, review

Shown filled in for an invented organisation, "Example Relief Foundation", a 60-person humanitarian NGO with offices in two countries. Names, figures and tools are illustrative. Nothing here describes a real client.

A client's policy is drafted from its own tool inventory, data, funder requirements and interviews with the people it governs, then taken through one board round.

This is an internal governance document. It is not legal advice and it does not certify the organisation against any standard. Where a legal opinion is needed, the practice says so and stops.

Sample v1.0 · 17 October 2026 · M.A.I. Consulting · mai4consulting.com

Contents

1. Purpose and scope 4
2. Five terms everyone uses the same way 4
3. Permitted uses 4
4. Red lines 5
4.1 Inputs that never enter any tool 5
4.2 Decisions that are never delegated 5
5. Data classification 6
6. Approved tools 6
7. Verification: the four checks 7
8. Disclosure 7
9. Agents, connectors and automation 7
10. Logging and records 8
11. Escalation and incidents 8
12. Training, competence and ownership 9
13. Review 9
14. Relationship to law and standards 9
Annex A · Approved tools (illustrative) 10
Annex C · Permitted-use table (extract) 10
Annex D · Casework and protection 12
Annex E · Fundraising and donor intelligence 12
Annex F · Human resources 12
Annex G · Procurement and IT 12
Annex H · Templates 13
H.1 The one-line log 13
H.2 The decision ledger (four lines, five minutes) 13
H.3 The near-miss log (notice, name, narrow) 13
H.4 Incident report (first 24 hours) 13
H.5 Rationale ledger (one line per boundary) 13

If the table does not show page numbers, update it in Word (right-click, Update field).

How to read this sample. The structure is the one the practice uses for every client: a short umbrella policy that opens with what staff **may** do, followed by annexes only where a department's risk genuinely diverges. The umbrella changes little from client to client; the tables (permitted uses, data classes, approved tools) and the annexes are where a client's own work appears.

Clause numbers are stable so that a playbook, a training session or an audit can cite them ("cleared against AI Use Policy 3.4").

What a client's own version adds. Its tool inventory in Annex A, its funders' disclosure wording in Annex E, the data processing agreements in Annex B, and a permitted-use table built from interviews with each department. The umbrella clauses change by a few lines. The whole document is cleared with the data protection lead and taken through one board round; the practice does not give legal advice and says so where an opinion is needed.

Document control	
Organisation	Example Relief Foundation (illustrative)
Version	1.0, approved by the Board on [date]
Owner (AI Steward)	Head of Operations
Data protection lead	Data Protection Focal Point (reports to the Director)
Applies to	All staff, consultants, volunteers and interns, on any device and any account, when doing the Foundation's work
Next scheduled review	Six months from approval, or earlier if a trigger in clause 12 occurs
Related documents	Annex A Approved tools · Annex B Data processing agreements · Annex C Permitted-use table · Annexes D to G department rules · Annex H Templates (log, decision ledger, near-miss log, incident form) · Department playbooks · Training and attendance record

1. Purpose and scope

1.1 This policy states what people working for the Foundation may do with AI tools, with which data, on which tools, and what they must check, log and disclose. It exists so that useful work is done inside clear rules rather than quietly outside them.

1.2 It applies to every person doing the Foundation's work, on any device, including personal accounts and free tools. A task done for the Foundation on a personal account is inside this policy.

1.3 "AI tool" means any software that generates, summarises, translates, classifies or acts on text, data, images or audio from a prompt, including assistants built into office software (for example Copilot), chat assistants (for example Claude, ChatGPT, Gemini), agents that act in other systems, and features inside tools the Foundation already uses.

1.4 The Foundation does not build AI systems. It uses them. That makes it a deployer in the vocabulary of the EU AI Act, whose Article 4 (as amended in 2026) asks deployers to take measures to support AI literacy among staff. This policy, the training record and the playbooks are those measures. They are documentation, not a certification.

2. Five terms everyone uses the same way

Term	Meaning in this policy
Approved tool	A tool listed in Annex A, on the plan and with the settings stated there. Any tool not in Annex A is not approved, including the free tier of an approved tool.
Prompt and input	Anything typed, pasted, uploaded, dictated or connected to a tool, including files it is allowed to read.
Output	Anything a tool returns or does: text, tables, translations, summaries, actions in another system.
Personal and beneficiary data	Anything that identifies or could identify a living person, directly or in combination: names, case details, locations below district level, images, voices, identifiers, and characteristics such as health, legal status or ethnicity. Beneficiary data is personal data about the people the Foundation serves and is always Class 4 (clause 5).
Agent	A tool configured to plan and carry out several steps, using other tools or systems, before returning. An agent can read, write or send; which of these it may do is set per task (clause 9).

3. Permitted uses

3.1 Permissions come first. Each permission names the task, the safeguard and the data boundary in one sentence. If a task is not listed here or in Annex C, ask the AI Steward; the default answer for a task that uses only Class 1 or Class 2 data is yes, recorded in Annex C at the next revision.

3.2 All staff may use an approved tool to draft, summarise, restructure, translate for review, rewrite in plain language, and prepare meeting notes and follow-ups, provided that the input contains no Class 3 or Class 4 data, every figure, name, date and rule in the output is checked against the source before it is relied on, and the person who sends or files the result remains its author of record.

3.3 All staff may use an approved tool for research on public sources, provided that every citation is opened and read before it is quoted, and the output is treated as a lead until verified.

3.4 Programme staff may use an approved tool to draft donor narrative reports from internal notes and the previous report, provided that no beneficiary name, case identifier or location below district level is entered, and that every figure is verified against the source file before the draft leaves the department.

3.5 Fundraising staff may use an approved tool to draft proposals against a funder's template, build eligibility checklists from a call for proposals, and summarise public information about institutional funders, provided that no figure is accepted without recomputation against the budget file and that no profile of a named individual is compiled (Annex E).

3.6 Finance and administration staff may use an approved tool to draft budget narratives from a spreadsheet, build procurement comparison tables from supplier documents, and draft procedures, provided that no bank, payroll, supplier-identifier or unpublished financial data is entered and that the tool's arithmetic is never accepted as the figure.

3.7 Human resources staff may use an approved tool to draft job descriptions, interview question banks, staff-facing explanations of policies and onboarding material, provided that no candidate or employee personal data is entered and that no screening, selection, performance or disciplinary judgement is informed by tool output (Annex F).

3.8 Communications staff may use an approved tool to draft press releases, social copy, briefing notes from long reports and first-draft translations, provided that nothing is published without a named owner, a source check and, for translations, a bilingual reviewer.

3.9 Leadership may use an approved tool to summarise board papers, draft decision memos with options and prepare scenario notes, provided that the decision, the rejected option, the risk owner and the sign-off are written by the accountable person and that AI assistance in a board paper is stated on the paper.

3.10 The full table of permitted uses by role (role, task, safeguard, data boundary) is Annex C. The playbook each department works from is cleared against Annex C and cites it.

4. Red lines

4.1 Inputs that never enter any tool

- Personal or beneficiary data (Class 4) in any tool, unless clause 5.3 applies and the use is recorded.
- Case files, referrals, safeguarding reports, grievances, medical or legal details about any person, in whole or in part.
- Unpublished financial statements, draft budgets, bank, payroll and supplier identifiers, passwords, tokens and keys.
- Donor or partner information received in confidence, and any document marked Confidential or Restricted by its source.
- Anything at all in a tool that is not on Annex A.

4.2 Decisions that are never delegated

No tool output may decide, recommend as the sole basis, or be configured to act on any of the following. A person decides, and their name is on it.

- Whether a person is eligible for assistance, and the ending or reduction of assistance.
- Safeguarding judgements and referrals, including whether a concern is reported.
- Hiring, promotion, discipline, grievance outcomes and the ending of employment.
- Authorisation of any payment, signature of any contract, statement or year-end account.
- Public statements on live or contested matters, and crisis communications.
- Legal positions and anything that will be submitted to a court, regulator or authority.

The list is short on purpose. Everything not on it is governed by clause 3 and the four checks, not by prohibition.

5. Data classification

5.1 Every document and every prompt falls into one of four classes. The test is a single question: **who is harmed if this appears somewhere it should not?**

Class	Definition	Examples	May enter
1 · Public	Already published by the Foundation or by its source. Nobody is harmed by disclosure.	Annual report, published policies, public funder guidelines, press releases, legislation	Any approved tool, including web search
2 · Internal	Not published, but disclosure would cause inconvenience rather than harm.	Internal procedures, templates, meeting notes without personal data, draft communications, aggregated indicators	Any approved tool on the organisational plan (Annex A), never a free tier
3 · Confidential	Disclosure would harm the Foundation, a partner or a funder.	Unpublished financials, draft budgets, partner agreements, donor correspondence, security plans, unannounced decisions	Only tools marked "Class 3" in Annex A, inside a Project or workspace restricted to the people entitled to see it
4 · Restricted	Disclosure would harm a person. All personal and beneficiary data.	Case files, beneficiary lists, HR records, health, legal status, images and voices of identifiable people, locations below district level	No AI tool, unless 5.3 applies

5.2 When in doubt between two classes, use the higher one. When in doubt whether something identifies a person, treat it as Class 4.

5.3 Class 4 data may be entered only into a tool covered by a data processing agreement listed in Annex B, for a use that the Data Protection Focal Point has recorded in the register, after de-identification where the task allows it. "De-identified" means that a reasonable reader of the output could not work out who is meant; replacing a name with an initial does not qualify.

5.4 A data protection impact assessment is run before any new use that involves Class 4 data, profiling of individuals, automated decisions about people, or a new tool that reads Class 3 or 4 data by connector. The Data Protection Focal Point decides whether it is triggered, using the Foundation's DPIA trigger test.

6. Approved tools

6.1 Annex A lists each approved tool with the plan, the account type, the settings it must have (training on inputs off, retention, sharing defaults), the highest data class it may receive, the owner, the date approved and the date of next review. A tool is approved for a plan and settings, not as a brand: the free tier of an approved tool is not approved.

6.2 Staff use their Foundation account, not a personal one. Where a personal account is the only option, the task must be Class 1 only and the use is logged.

6.3 New tools and new features in approved tools go through the trust ladder before use on real work: sandbox on Class 1 data, a named owner, a test on the Foundation's own documents, a check against this policy, then a listing in Annex A. "Experimental" features stay in the sandbox.

6.4 The tool inventory (which tools staff actually use, on which data) is kept by the AI Steward and refreshed before each review. It is built in an amnesty spirit: reporting a tool you have been using is never penalised.

7. Verification: the four checks

7.1 Before any AI-assisted output is relied on, sent, filed or published, the person responsible runs four checks and can show that they did:

Check	Question	Fails when
Figures	Can every number be traced to a source document I can point at?	A figure appears in the output that is in no source. The commonest and most expensive error.
Facts	Are names, dates, eligibility rules and citations checked against the original, not the summary?	A rule is quoted from the summary; a citation is cited unopened.
Language	Read once for tone and for deficit-based or stereotyping wording about the people we serve.	A phrase we would not use about a person in the room.
Defensibility	Would I say this sentence out loud to the funder, the board or the community?	The honest answer is no.

7.2 Checking time is real work time and is counted when a task is timed. If checking exceeds the time saved, the task is a candidate for the "do not use AI" column of the playbook.

7.3 For translation, the check is sentence-by-sentence review by a named bilingual reader. For monitoring and evaluation data, the check is that no outlier was dropped, no gap was filled and no causal claim was added by the tool.

8. Disclosure

8.1 Where an approved tool has contributed to a document submitted to a funder, the submission states so in the form agreed with that funder, naming the task and the safeguard ("the first draft of the narrative section was prepared with an AI tool from internal notes; all figures were verified against the results table by the programme officer"). The responsible officer remains the author of record.

8.2 Board papers state where AI assisted and the accountable person who wrote the decision, the rejected option and the risk owner.

8.3 Published material, including social media and translations, is disclosed where the channel, the funder or the law requires it, and always when the content was substantially generated rather than drafted and rewritten.

8.4 Communication to beneficiaries and communities does not use AI-generated images or voices of real or realistic people, and any AI-drafted message to a beneficiary is reviewed by the person who would have written it.

8.5 Vague disclosure ("AI was used") is avoided. Over-disclosure that implies a tool made a judgement a person made is also avoided.

9. Agents, connectors and automation

9.1 Before an agent or connector is given access to any system, the owner writes down its blast radius: everything it could reach on its worst day, and the worst wrong action it could take. Access is granted per task, not per agent, and read, write and send are separated.

9.2 Default permissions are read-only. Write access is granted only where the output is reviewed before it takes effect, and send access (email, payments, publishing, deletion) only with the Director's written approval recorded in Annex A.

9.3 Browser agents working inside a logged-in session inherit everything that login can reach. They are not allowed in sessions where irreversible or Class 3 and 4 actions are available (banking, HR systems, case management, the Foundation's public channels).

9.4 Any document, web page or message an agent reads is untrusted content and may contain instructions aimed at the agent. Agents read only from curated sources, the shared drive folders listed for them, and never from mailboxes or ticket queues that many people can write to, unless the use is approved under 9.2.

9.5 No agent, Skill or automation is used on real work until it has a named owner (not only its builder), a one-page operating guide, a test set of known cases it has passed, and a listing in the permissions record. A set-up with no owner is switched off at the next review.

9.6 The tasks in clause 4.2 are never configured into an agent, whatever the safeguard.

10. Logging and records

10.1 The one-line log. For any AI-assisted task that leaves the department, the person records one line: tool, task, date, disclosure needed yes or no. Department logs are kept in the shared folder and are the evidence that this policy is in use.

10.2 The decision ledger. Where AI output shaped a decision that affects a person, a funder or a public position, the accountable person records four lines: what the tool contributed, what the person decided differently or additionally, who signed, and where the output is kept. Retained for the life of the decision plus the funder's retention period.

10.3 The training and attendance record. Who attended which session, when, what was covered and at what level, including consultants and volunteers. Kept by the AI Steward. Together with this policy, the tool inventory, the readiness scores and the review record, it forms the evidence file a board, funder or auditor asks for.

10.4 The near-miss log. Anything that nearly went wrong (a paste stopped at the last moment, a figure caught at the check, an agent that reached further than intended) is recorded in three lines: notice, name, narrow. No penalty attaches to an entry. The log is read at every review.

11. Escalation and incidents

11.1 The escalation contact is the AI Steward; for anything involving personal data, the Data Protection Focal Point. Both names and a deputy for each are on the intranet front page.

11.2 Escalation-worthy is defined broadly: Class 3 or 4 data entered into a tool, an unapproved tool used on Class 2 or above, an output relied on that turned out to be wrong after it left the building, an agent action nobody intended, a prompt that produced instructions from a document, or any doubt at all.

11.3 The 24-hour rule. From discovery, the person who found it tells the escalation contact within 24 hours, by any channel, with what happened, what data, which tool and what has been done. The contact decides within the same 24 hours whether it is contained, whether the data protection breach procedure starts, and who else is told.

11.4 Reporting is never penalised. Failing to report is a conduct matter.

11.5 Every incident and every near miss is reviewed for what to change: a clause, a tool setting, a playbook line, a training gap. The change is recorded in the review record.

12. Training, competence and ownership

12.1 Every person doing the Foundation's work completes the general session on this policy and the four competencies (Delegation, Description, Discernment, Diligence) within three months of joining, before using an approved tool on Class 2 data or above.

12.2 The Foundation's training floor is level 3 of the seven capability levels: the person writes a full brief, grounds it in the real document, runs the four checks and keeps the log. Staff who build set-ups for others (level 6) are named in the training record as champions.

12.3 Five seats own AI at the Foundation: the **Sponsor** (Director: approves this policy and send permissions), the **AI Steward** (Head of Operations: owns the policy, the tool inventory, the training record and the review), **Use Owners** (one per department: own the playbook and its set-ups), **Champions** (named staff at level 4 or above who answer questions and run office hours), and the **Assurer** (Data Protection Focal Point: data classes, DPIAs, incidents).

13. Review

13.1 This policy is reviewed every six months by the AI Steward with the Use Owners and the Data Protection Focal Point, against four questions: Did anyone need a rule that was not here? Did a rule get routed around? Did a tool, plan or setting change? Did the law or a funder's requirement change? The answers and the resulting changes are recorded.

13.2 An earlier review is triggered by any one of: the escalation contact leaves; an approved tool changes its data terms or adds a feature that touches a data class; the same escalation occurs twice; a change in law or in a major funder's requirements.

13.3 Playbooks are revised by the department the week an exception appears. Annex A is updated whenever a tool is added, removed or changed. The readiness re-score at six months is read alongside this review.

13.4 The reasons behind each boundary in this policy are kept in a short rationale ledger (Annex H) so that the "why" survives changes of staff and of tools.

14. Relationship to law and standards

- **Data protection.** This policy sits under the Foundation's data protection policy. Where they differ, the stricter rule applies. The DPIA trigger test and the breach procedure are the data protection policy's, referenced here, not duplicated.
- **EU AI Act.** The Foundation is a deployer. Article 4 as amended asks for measures that support AI literacy; clause 12 and the training record are those measures. The Foundation does not operate any system it has assessed as high-risk; if a use case ever approaches that category, the Assurer stops it pending advice.
- **Standards.** The structure of this policy borrows from the NIST AI Risk Management Framework (Govern, Map, Measure, Manage) and from ISO/IEC 42001 as a checklist, at a size proportionate to a 60-person organisation. The Foundation does not claim conformity or certification to either.
- **Funder requirements.** Where a funder's own AI or data rules are stricter, they apply to that grant and are recorded in Annex E.

Annex A · Approved tools (illustrative)

Tool	Plan and account	Required settings	Highest class	Owner	Approved	Next review
Microsoft 365 Copilot	Foundation tenant, licensed users	Enterprise data protection on; web grounding off for Class 3; no personal accounts	3 (inside the tenant)	IT lead	[date]	[+6 months]
Claude (Team plan)	Foundation workspace, named seats	Training on inputs off (default on this plan); memory off by default, on by Use Owner decision; Projects restricted to members entitled to the files	3 (restricted Projects only)	AI Steward	[date]	[+6 months]
Gemini (Workspace)	Foundation Google Workspace	Workspace data terms; extensions limited to Drive folders listed in the permissions record	2	IT lead	[date]	[+6 months]
DeepL (Pro)	Foundation account	Document translation only; no free tier; Class 2 only	2	Communications lead	[date]	[+6 months]
Any free tier of the above	Not approved					
Browser agents (any)	Not approved in logged-in sessions; demonstration use on Class 1 only, by champions	Per clause 9.3	1	AI Steward	[date]	[+6 months]

Annex B (not reproduced in this sample) lists the data processing agreements in force, by tool and sub-processor, with the retention terms the Data Protection Focal Point has checked.

Annex C · Permitted-use table (extract)

One row per role and task. The safeguard column is what the person must do; the data boundary is what must not be in the input. Department playbooks cite the row.

Role	Task	Safeguard	Data boundary
All staff	Summarise a long public or internal document	Spot-check three claims against the original	Class 1 and 2
All staff	Meeting notes to actions and follow-up email	Owner and date confirmed by the person; personal details added by hand	Names of staff only; no beneficiary or partner personal data
All staff	Plain-language rewrite	Side-by-side read for meaning loss	As the source document's class
Programmes	Donor narrative report, first draft	Every figure traced to the results table; previous report attached as the model	No beneficiary name, case identifier or location below district
Programmes	Indicator wording for a logframe	Checked against the funder's indicator guidance	Class 2
M&E	Narrative and charts from settled data	No outlier removed, gap filled or causal claim added by the tool	Aggregated data only
Fundraising	Proposal draft against a funder template	Budget figures recomputed from the budget file	Draft budget stays out; figures entered by hand after check
Fundraising	Eligibility checklist from a call	Each rule checked against the call text, article by article	Class 1
Fundraising	Institutional funder research	Public sources only; citations opened	No profile of a named individual (Annex E)
Finance	Budget narrative from the spreadsheet	Arithmetic never accepted from the tool	No bank, payroll, supplier identifiers

Role	Task	Safeguard	Data boundary
Finance	Procurement comparison table	Supplier figures checked against quotes	Supplier documents as received, Class 3 where marked
HR	Job description, interview question bank	Reviewed for bias; approved by hiring manager	No candidate or employee data
HR	Aggregated staff survey themes	Minimum group size ten; no quotes attributable	Aggregated only
Communications	Press release, social copy	Named owner; source check; house voice read	Class 1 and 2; nothing on live or contested matters
Communications	Translation first draft	Bilingual reviewer, sentence by sentence	As the source document's class
Leadership	Board paper summary; decision memo with options	Decision, rejected option, risk owner and sign-off written by the accountable person; AI use stated on the paper	Class 3 inside the restricted workspace only
Legal and protection	Summary of published guidance	Reviewed by the legal focal point	No case file, referral or client communication

Annex D · Casework and protection

D.1 Caseworkers may use an approved tool for anonymised summarisation of published guidance only. No case file, referral or client communication may be entered, in whole or in part, and no eligibility or safeguarding decision may be informed by tool output without a documented human review.

D.2 Safeguarding language checks: external content is compared against the written safeguarding communications rulebook by a dedicated, tested Skill, with a named human for borderline and consent questions. The Skill never sees case data; it sees the draft text and the rulebook.

D.3 Any image or voice of an identifiable beneficiary is Class 4 and never enters a tool.

Annex E · Fundraising and donor intelligence

E.1 Research on institutional funders from public sources is permitted under 3.5. Compiling wealth estimates, personal characteristics or networks of a named individual is personal data processing and requires the Data Protection Focal Point's sign-off and a register entry before it starts.

E.2 Where a funder's terms require disclosure of AI use, the form of words is agreed with that funder once and recorded here, by funder.

E.3 Draft budgets stay out of every tool. Figures are entered by hand after recomputation.

E.4 How personal a message claims to be sets a second boundary: a message that presents itself as individually written by a named officer is written or fully rewritten by that officer.

Annex F · Human resources

F.1 Permitted: scheduling, drafts of job postings and descriptions, interview question banks, staff-facing explanations of policy, onboarding material, aggregated survey themes (minimum group size ten).

F.2 Never: screening or ranking candidates, assessing performance, drafting or informing disciplinary, grievance or termination outcomes, entering any individual's record, and any inference about a person's characteristics.

F.3 Interview notes about a candidate are Class 4 and are never entered, even to "tidy them up".

Annex G · Procurement and IT

G.1 Supplier documents may be compared and summarised under 3.6; award decisions and contract signature stay with the people named in the procurement procedure.

G.2 Before any AI tool or feature is bought or enabled, the IT lead and the AI Steward answer: What does it do with inputs? Where is data stored and for how long? Who are the sub-processors? Can we export our data and our set-ups if we leave? What does it cost per completed task, including the review? The answers are filed with Annex A.

G.3 Access grants to systems for agents follow clause 9 and are recorded in the permissions record with the approver's name.

Annex H · Templates

H.1 The one-line log

Date	Person	Tool	Task	Class of input	Checks run (F/F/L/D)	Disclosure needed	Where filed
[date]	[initials]	Claude Team	Donor report Q3, results section first draft	2	Y/Y/Y/Y	Yes, funder form	[path]

H.2 The decision ledger (four lines, five minutes)

Line	Entry
What the tool contributed	[e.g. ranked the twelve applications against the published criteria and drafted a summary of each]
What the person decided differently or additionally	[e.g. moved two applications up after reading the originals; rejected the tool's reading of criterion 3]
Who signed, and when	[name, role, date]
Where the output and the sources are kept	[path or reference]

H.3 The near-miss log (notice, name, narrow)

Date	Notice: what nearly happened	Name: which rule or limit it touched	Narrow: what we changed so it is less likely next time	Entered by
[date]	A field note with two beneficiary names was about to be pasted for summarising	Clause 4.1, Class 4	Added "names out first" as the first line of the programme playbook; template now has a redaction step	[initials]

H.4 Incident report (first 24 hours)

- What happened, in two sentences. When discovered. By whom.
- Which tool, which plan, which account. What data, which class, how much.
- What has been done already (deleted from the tool, chat closed, access revoked).
- Escalation contact informed at [time]. Decision: contained / breach procedure started / further review.
- Follow-up: the clause, setting, playbook line or training change recorded in the review record.

H.5 Rationale ledger (one line per boundary)

Boundary	Why it exists	Who set it	Revisit when
No locations below district level in any tool	Combining location with programme type identified households in a 2025 partner review	Protection lead	If data terms change to in-tenant processing only
No browser agents in logged-in sessions	The session can reach banking and the case system; worst wrong action is irreversible	AI Steward and IT lead	If a tool offers session-scoped, read-only agent access